



SOUTHVILLE INTERNATIONAL SCHOOL AND COLLEGES

1281 Tropical Avenue Corner Luxembourg Street, BF Homes International, Las Piñas, 1740

WePrivacy: A Data Privacy Monitoring System

A Thesis-Style Report

Presented to the Faculty of

Southville International School and Colleges

In Partial Fulfillment of the Requirements for the

Methods of Research Course

Prepared by:

Krizan M. Singh

Jerome Michael A. Briones

Submitted to:

Sir John Pio Anthony Buena, CCPE

June xx, 2026

TABLE OF CONTENTS

Project Background

In modern enterprise operations, organizations face an increasingly complex digital landscape marked by massive data volumes, rampant cybersecurity threats like SMS scams and phishing, and the rapid adoption of Artificial Intelligence (AI). While technologies like AI and deep data analytics offer immense operational value, they introduce severe privacy challenges—such as opaque data processing pipelines, re-identification risks, and unmanaged third-party tracking. In the Philippines, the National Privacy Commission (NPC) strictly enforces the Data Privacy Act of 2012 (RA 10173) to protect individual data subjects from these evolving vulnerabilities.

Compounding this external pressure, many organizations continue to handle data compliance manually or struggle to clearly delineate responsibilities between Personal Information Controllers (PICs) and Personal Information Processors (PIPs). Relying on fragmented spreadsheets to track complex automated data flows or to manage urgent data breach timelines is no longer legally or operationally viable. There is an immediate requirement for an automated compliance management platform that addresses contemporary tech risks while strictly adhering to the NPC's shifting regulatory directives.

Statement of the Problem

Organizations currently face significant challenges in upholding data privacy standards due to the lack of a centralized governance tool. Specifically, the following problems have been identified:

- **Severe Penal Liabilities and Fines:** Under RA 10173, data privacy violations—including unauthorized processing, malicious disclosure, and systemic negligence—carry heavy criminal penalties, including multi-million peso fines and mandatory imprisonment for corporate officers.
- **Opaque AI and Automated Processing Risks:** The deployment of modern automated tools often results in "black-box" data scraping, algorithmic bias, and secondary data usage without explicit consumer consent.
- **Conflated PIC and PIP Responsibilities:** Organizations fail to properly log and audit whether they are acting as the primary Controller (PIC) or a third-party Processor (PIP), leading to severe gaps in contractual and legal accountability.
- **Inability to Meet Rigid Breach Notification Timelines:** Managing a data breach manually makes it impossible to securely triage incidents and coordinate reporting within the mandatory 72-hour window. This risk is amplified by the NPC's strict 2026 procedural rules, which penalize companies that submit conflicting or legally incompatible relief requests during a breach response.
-

General Objective

The primary objective of this project is to develop and deploy a centralized Data Privacy Compliance Management System (DPCMS). This system will enable the organization to safeguard user trust, map complex automated data lifecycles (including AI pipelines), clarify PIC/PIP boundaries, and automate strict compliance reporting to eliminate the risk of criminal litigation and regulatory penalties.

Specific Objectives

1. To develop a centralized repository for tracking and verifying data subject consent, including provisions for opt-in, opt-out, and right to be forgotten requests.
2. To automate the creation, updating, and auditing of the organization's Record of Processing Activities (RoPA).
3. To provide real-time compliance reporting through a comprehensive DPO executive dashboard.
4. To implement a comprehensive audit logging mechanism that securely tracks system access, user activities, and data processing events to ensure accountability

Scope and Limitations

Scope

The scope of the DPCMS encompasses the comprehensive management of organizational data governance across all operational business units. The platform features dedicated modules for dynamic RoPA building, automated PIAs for emerging technologies (such as AI model deployments), and a centralized tracking repository for consumer consent and data deletion requests. Crucially, the system covers data breach triage workflow automation, providing structural guidance from initial impact evaluation up to the point of generation for full NPC regulatory reports. It explicitly maps out data flows between Personal Information Controllers (PICs) and Personal Information Processors (PIPs), ensuring contract compliance is verified across all third-party vendors.

Limitations

While the system provides absolute administrative and governance oversight, it operates under distinct boundaries. The DPCMS is strictly a compliance recording and risk-management tool; it does not serve as active network cybersecurity infrastructure, such as intrusion prevention systems or firewalls designed to halt active phishing or network hacks. Additionally, while the system logs and flags opaque data usage or potential bias risks in AI workflows, it cannot programmatically alter or fix external proprietary algorithms. Finally, the baseline compliance automation logic, reporting forms, and strict submission timelines are built specifically to satisfy Philippine NPC regulations and will require localization modules for international frameworks like GDPR.

Applicable Law(s)

The system is engineered to enforce compliance with Republic Act No. 10173, also known as the Data Privacy Act of 2012. This legislation penalizes systemic corporate negligence, unauthorized data processing, and improper data disposal with heavy monetary fines and imprisonment for culpable officers. The DPCMS directly mitigates these criminal liabilities by enforcing automated guardrails across the entire corporate data lifecycle. It ensures that personal and sensitive information is gathered transparently, handled securely, and stored only for explicitly stated purposes. By embedding these statutory boundaries into daily workflows, the platform structurally protects the organization from severe penal litigation.

Furthermore, the platform integrates the operational mandates outlined in the Implementing Rules and Regulations (IRR) of RA 10173 and foundational NPC frameworks. The IRR requires organizations to establish rigorous organizational, physical, and technical security measures to safeguard user information. Our system satisfies these specific mandates through its strict role-based access management, end-to-end data encryption architectures, and automated consumer consent validation logging. Crucially, the platform incorporates the distinct legal definitions and behavioral boundaries separating a Personal Information Controller (PIC) from a Personal Information Processor (PIP). This clear division ensures that vendor data-sharing agreements and localized data operations always mirror the precise administrative standards demanded by the commission.

Finally, the system's compliance workflows are updated to mirror the rigorous procedural changes introduced by the National Privacy Commission, including NPC Advisory No. 2026-02. This regulatory framework mandates strict timelines for full breach reporting and demands clear, non-contradictory legal remedies from affected entities. The NPC explicitly clarifies that organizations are prohibited from filing mutually incompatible requests, such as simultaneously seeking a notification exemption while asking to postpone that same notification. Our breach response module addresses this strict policy by utilizing linear, automated triage pathways that eliminate conflicting procedural submissions. By enforcing these unalterable regulatory timers and documentation standards, the software guarantees full compliance with the NPC's latest operational protocols.

Proposed Features

To meet mandatory system and functional requirements, the DPCMS distinctly separates its core capabilities into **five (5) Major Functional Modules**:

1. **User & Access Management Module:** Handles different access levels across the system through strict Role-Based Access Control (RBAC). It is programmed to support at least three (3) distinct user roles (e.g., System Administrator, Data Protection Officer, and Standard User/Privacy Champion) to ensure secure governance.
2. **Consent & Privacy Notice Module:** Contains the Consent Management (Consent Tracking Module) to monitor and track user consent agreements accurately. It also houses Privacy Notice Management, allowing the organization to efficiently manage, update, and deploy its privacy policies.
3. **Data Mapping & Registry Module:** Features the Personal Data Inventory to keep an exact record of what personal data the organization holds. This is directly linked to the Data Processing Registry, which formally documents how that personal data is being processed, stored, and utilized (including AI pipelines or automated tools).
4. **Compliance & Checklisting Module:** Provides a functional Compliance Checklisting tool structured to ensure organizational adherence to the Data Privacy Act of 2012 (RA 10173). It also features a visual Compliance Dashboard, acting as a high-level interface to monitor the overall compliance status of the organization in real-time.
5. **Audit & Report Generation Module:** Maintains tamper-proof Audit Logs to track user activities, access events, and system changes continuously. It includes powerful Report Generation and Export Functionality, enabling the creation of official documents detailing system status. Users can specifically generate the mandatory Compliance Report and Audit Trail Report, fully exportable to both PDF and Excel formats.

Initial System Concept

Component	Description
Architecture	Hosted within a secure Virtual Private Cloud (VPC) with automated redundancies to protect compliance records against regional service disruptions.
Access Control	Strict Role-Based Access Control (RBAC) supporting the mandatory minimum of three distinct roles: System Administrator, DPO, and Standard User. Multi-Factor Authentication (MFA) is strictly enforced to block phishing or credential leaks.
Data Security	End-to-end data encryption. Compliance records and audit trails are encrypted using AES-256 at rest and TLS 1.3 in transit to prevent data exposure or malicious disclosure.
Export Engine	A built-in document rendering layer that converts real-time system data, compliance checklists, and audit logs into formatted, official PDF and Excel (.xlsx) reports.
Immutable Audit Trail	A write-once, read-many (WORM) logging architecture that captures every user action, system change, or breach report timestamp to serve as legally defensible proof against corporate negligence.

References

Baker McKenzie. (2026, June). *Philippines: Data breach notification procedure further clarified*. <https://www.bakermckenzie.com/en/insight/publications/2026/06/philippines-data-breach-notification-procedure-further-clarified>

National Privacy Commission. (n.d.). *Breach reporting*. <https://privacy.gov.ph/pips-and-pics/breach-reporting/>

National Privacy Commission. (n.d.). *Republic Act 10173 – Data Privacy Act of 2012*. <https://privacy.gov.ph/data-privacy-act/>

Office of the Victorian Information Commissioner. (n.d.). *Artificial intelligence and privacy: Issues and challenges*. <https://ovic.vic.gov.au/privacy/resources-for-organisations/artificial-intelligence-and-privacy-issues-and-challenges/>

Romualdez Law. (n.d.). *Data privacy violations in the Philippines*. <https://romualdezlaw.com/data-privacy-violations-philippines/>

Telecom Review Asia. (n.d.). *Data privacy and security concerns in the Philippines telecom sector*. <https://www.telecomreviewasia.com/news/featured-articles/4192-data-privacy-and-security-concerns-in-the-philippines-telecom-sector/>

Termly. (n.d.). *Data privacy issues*. <https://termly.io/resources/articles/data-privacy-issues/>